Compte rendu – TP3

Sécurisation d'un serveur Linux – firewalld, durcissement SSH, journaux et détection – projet « Hélios »
Administration d'un Linux Server – Bachelor Informatique 2e année (BTC2), IPSSI Lille

Étudiant	Bilal Chaybouti
Date	4 novembre 2026
Environnement	VirtualBox – Rocky Linux 9.8 – `srv-core` (cible, 192.168.56.10) et `srv-edge` (administrateur / attaquant, 192.168.56.11)
Résultat	Missions 1 à 3 réalisées, critères de réussite validés – bonus non réalisé

Bilan des critères de réussite

Critère	Preuve	Statut
Zone par défaut `drop`, chaque interface dans sa zone	§1.2	✔
`nc -zv … 22` échoue, `ssh -p 2242 sysops@…` réussit par clé	§2.5 tests 1–2	✔
root et nadia refusés	§2.5 tests 3, 5	✔
`passwordauthentication no`, `allowgroups ssh-admins`	§2.6	✔
`semanage port -l` contient 2242	§2.4	✔
Lignes SSH-NEW générées par les tests	§1.5	✔
`journalctl --list-boots` ≥ 2 démarrages	§3.1	✔
`auditctl -l` ≥ 10 règles, événement `sudoers`	§3.3	✔ **(14 règles)**
Après l'attaque, l'ipset contient 192.168.56.11	§3.4	✔
`list-timers helios-watch-auth.timer` affiche une prochaine exécution	§3.4	✔

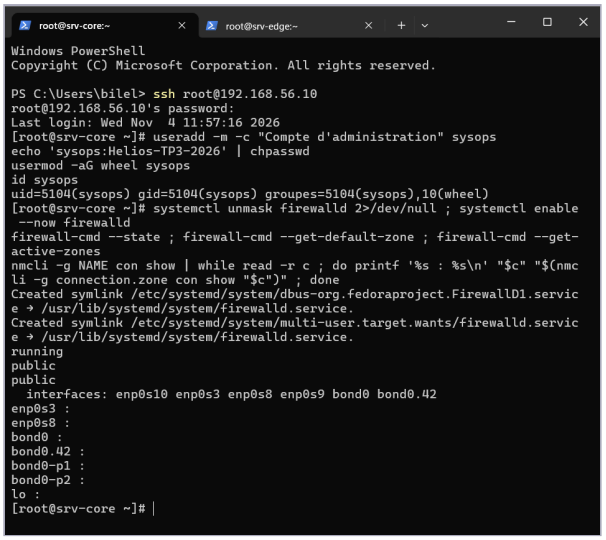
Écarts et adaptations par rapport à l'énoncé

Point	Adaptation
Compte `sysops` absent	Créé sur les deux VM (groupe wheel)
Connexion « admin » inexistante	La connexion de enp0s8 se nomme `enp0s8` : commandes adaptées
Accès de l'administrateur depuis l'hôte	Clé ed25519 de l'hôte Windows ajoutée pour sysops avant la coupure du mot de passe
Ordre 2.3 / 2.4	Port autorisé dans SELinux et le pare-feu **avant** tout redémarrage de sshd, pour ne pas se couper
`semanage` absent	Paquet policycoreutils-python-utils installé
Fichier caché `01-permitrootlogin.conf`	Découvert et supprimé (§2.6)
sshd en échec au boot	Corrigé par `net.ipv4.ip_nonlocal_bind=1` (§3.1)
Test sudo de julien par `su -c`	Non réalisable sans terminal ; événements privesc captés via sysops → sudo -i
Mission bonus	Non réalisée

Mission 1 – Pare-feu firewalld segmenté par zone

1.1 Remise en service

firewalld, arrêté au TP1, est réactivé. Au départ, toutes les interfaces sont dans la zone `public`, sans aucune segmentation.



Création de sysops, firewalld running, zone public pour toutes les interfaces

1.2 Une zone par interface

Interface	Connexion	Zone	Politique	Justification
enp0s3 (NAT)	enp0s3	**drop**	rien n'entre	Interface exposée vers Internet : aucun service n'y est publié, les paquets sont jetés sans réponse
enp0s8 (administration)	enp0s8	**work**	SSH seul, débit limité, source 192.168.56.0/24	Réseau d'administration : seul l'accès d'administration est utile
bond0 (métier)	bond0	**internal**	SSH + supervision 10051	Réseau métier de confiance, où passeront les flux Zabbix (TP4)
bond0.42 (VLAN transport)	bond0.42	**internal**	idem	Même niveau de confiance que le réseau métier

La zone est écrite dans le **profil NetworkManager** (`connection.zone`), et non dans firewalld : NetworkManager la réapplique à chaque activation de la connexion. La zone par défaut passe à `drop` : toute interface non déclarée est fermée.

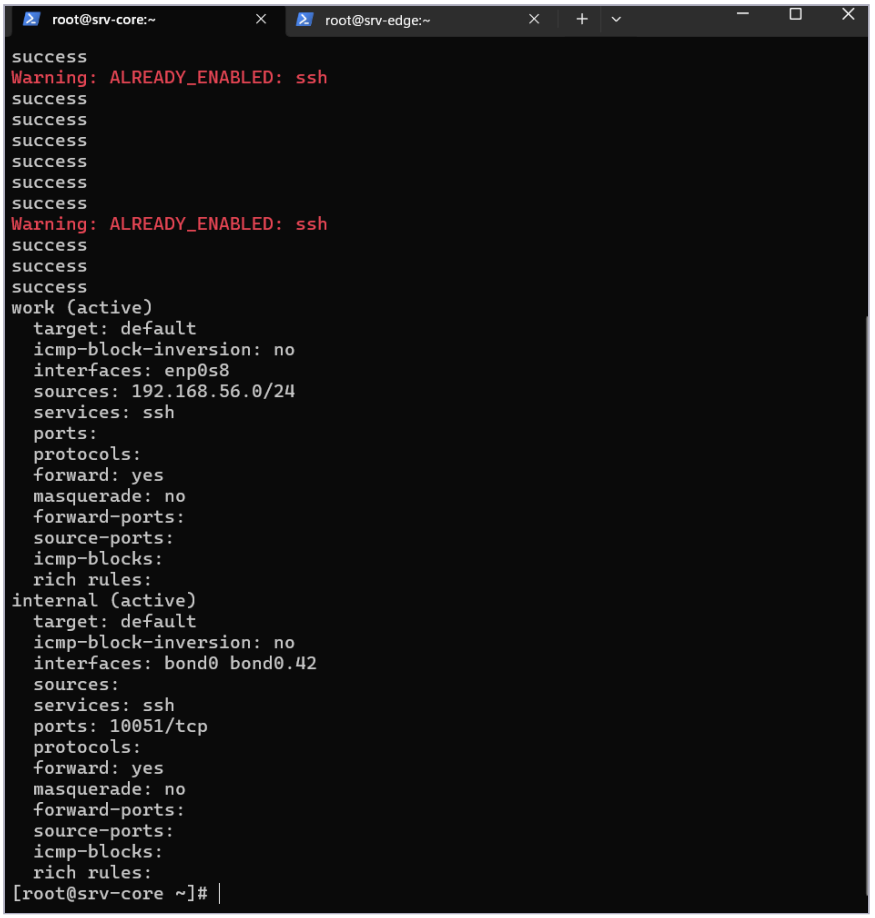


drop → enp0s3, work → enp0s8, internal → bond0 et bond0.42

enp0s9 et enp0s10, ports physiques du bond, n'ont pas de zone propre : le trafic IP est porté par bond0. Après le passage de la zone par défaut à drop, elles apparaissent dans `drop` (configs/zones.txt).

1.3 Ouvrir le strict nécessaire

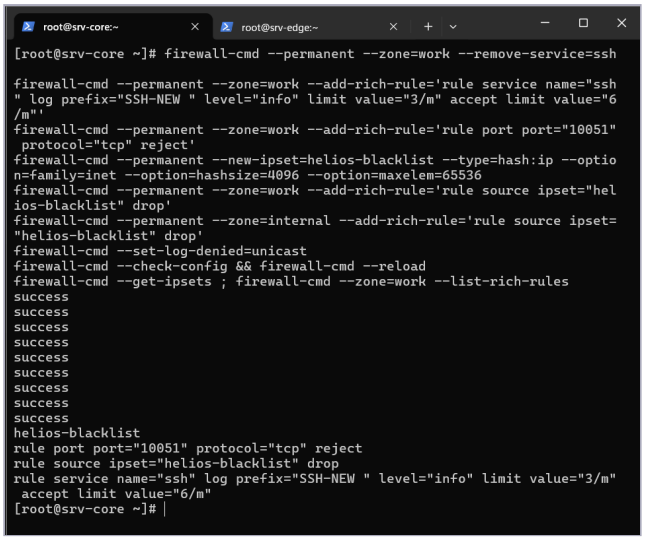
Les services ouverts par défaut et inutiles (cockpit, dhcpv6-client, mdns, samba-client) sont retirés ; work n'accepte plus que SSH depuis 192.168.56.0/24, et internal que SSH et 10051/tcp.



firewall-cmd --zone=work --list-all et --zone=internal --list-all

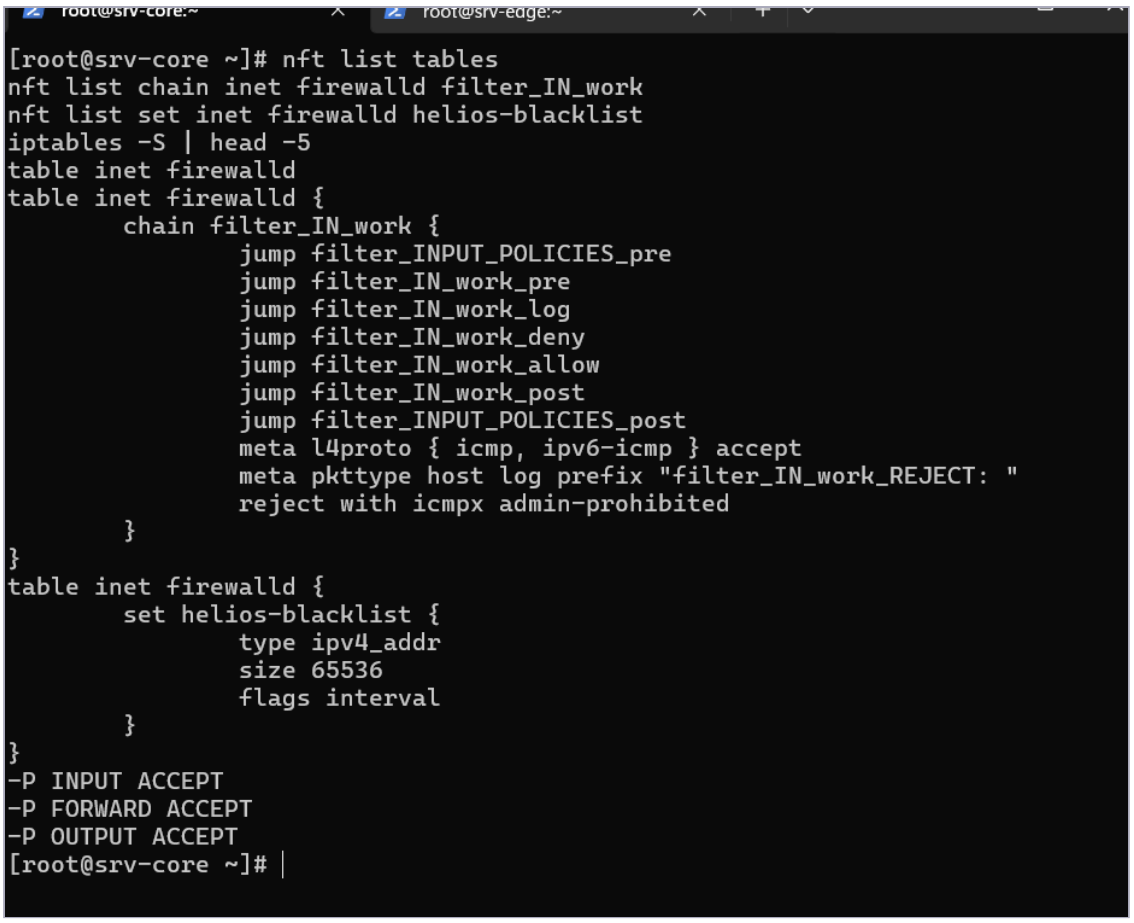
1.4 Règles riches et liste de blocage

- **SSH journalisé et bridé** : `log prefix="SSH-NEW" limit 3/m accept limit 6/m`. Chaque nouvelle connexion est tracée, et au-delà d'une rafale de 6, les connexions sont rejetées. La journalisation est elle-même limitée à 3 lignes par minute, ce qui empêche une attaque de saturer le disque.
- **Port 10051 refusé** sur la zone d'administration : la supervision reste cantonnée au réseau métier.
- **ipset helios-blacklist** (hash:ip, 65 536 entrées), avec une règle `drop` dans work et internal, alimenté automatiquement en Mission 3.
- `--set-log-denied=unicast` : les paquets refusés sont journalisés.



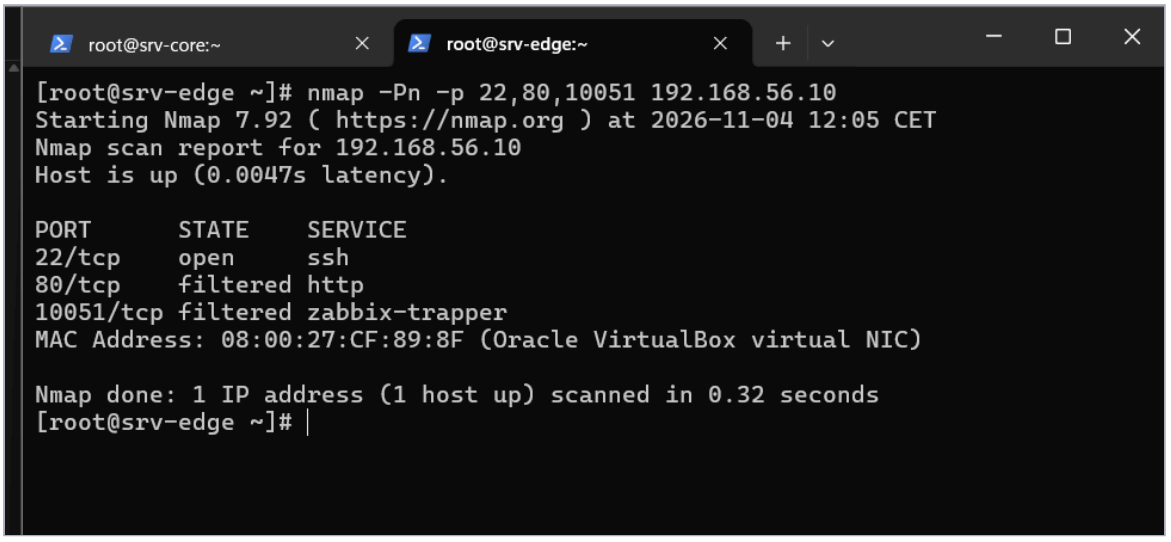
ipset créé et règles riches de la zone work

1.5 Ce que firewalld écrit réellement, et tests

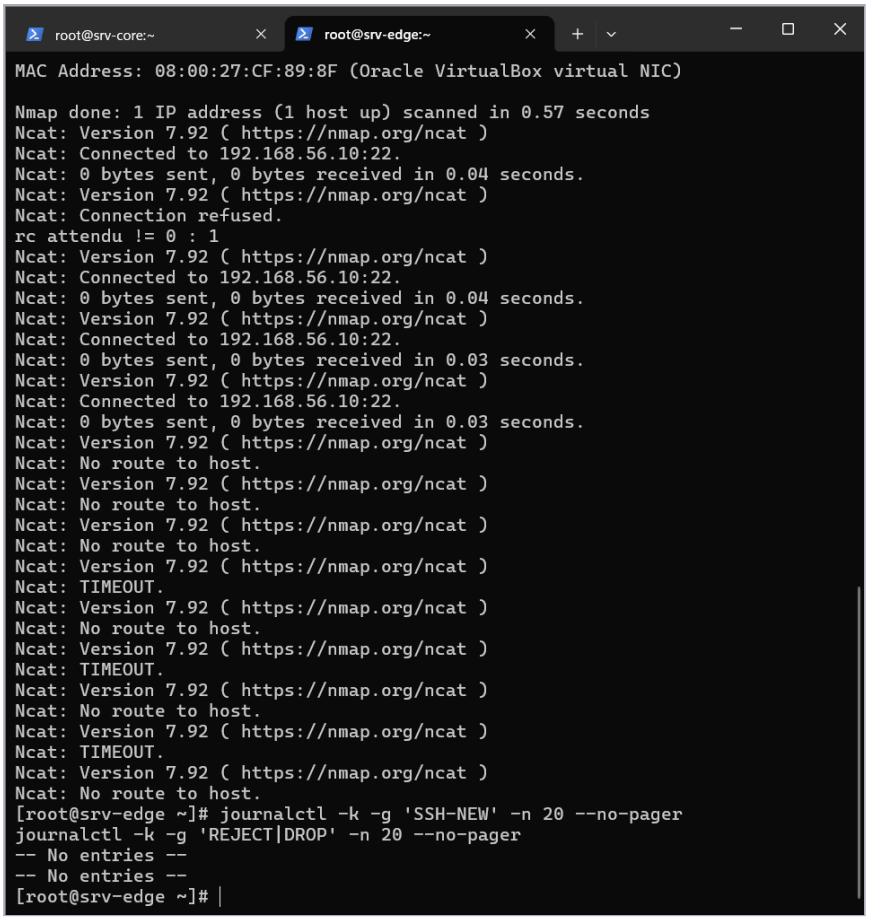


nft list chain inet firewalld filter_IN_work : sous-chaînes log/deny/allow puis reject final ; set helios-blacklist

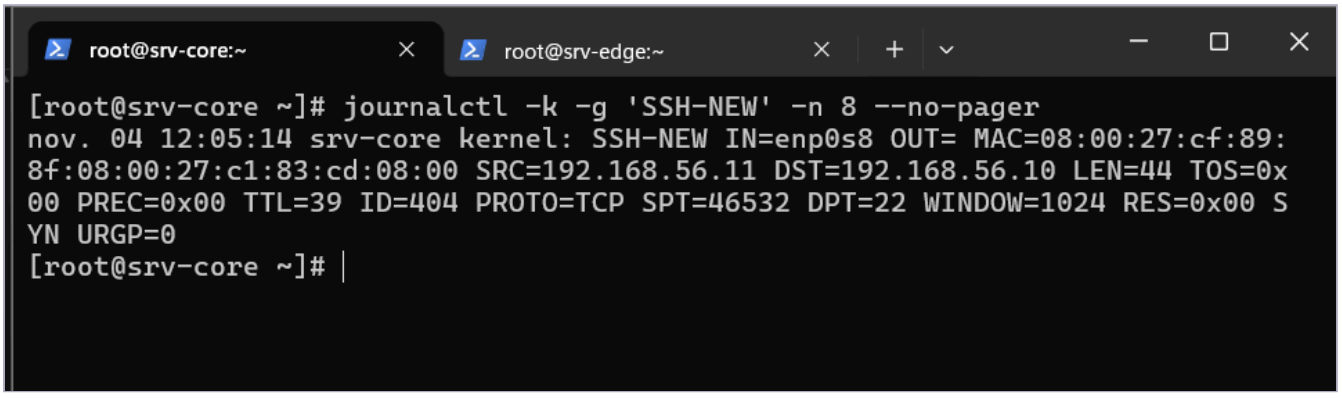
firewalld est une interface : le filtrage effectif est fait par **nftables** (table `inet firewalld`). `iptables -S` n'affiche que des politiques ACCEPT vides : sur Rocky 9, iptables-nft n'est qu'une couche de compatibilité.



nmap depuis srv-edge, avant durcissement SSH : 22 open, 80 et 10051 filtered



10051 refusé (rc=1) ; 12 connexions SSH : les premières passent, puis la limite de débit les bloque



Trace noyau SSH-NEW (source 192.168.56.11, port 22)



filter_IN_work_REJECT : paquets refusés, avec source et port (DPT=22 au-delà de la limite, DPT=80 du scan)

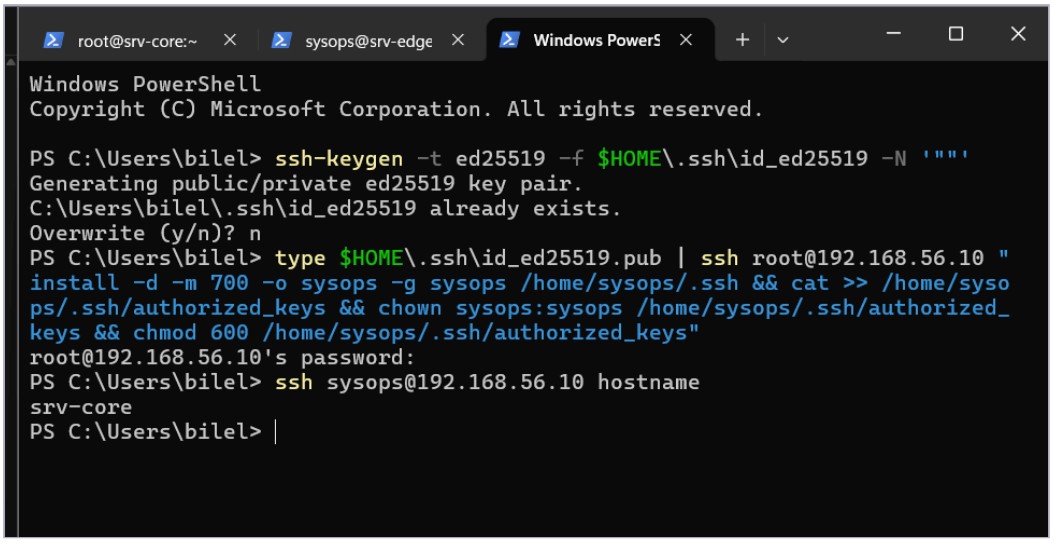
Mission 2 – Durcissement de sshd

2.1 Accès par clé préparé avant la coupure du mot de passe

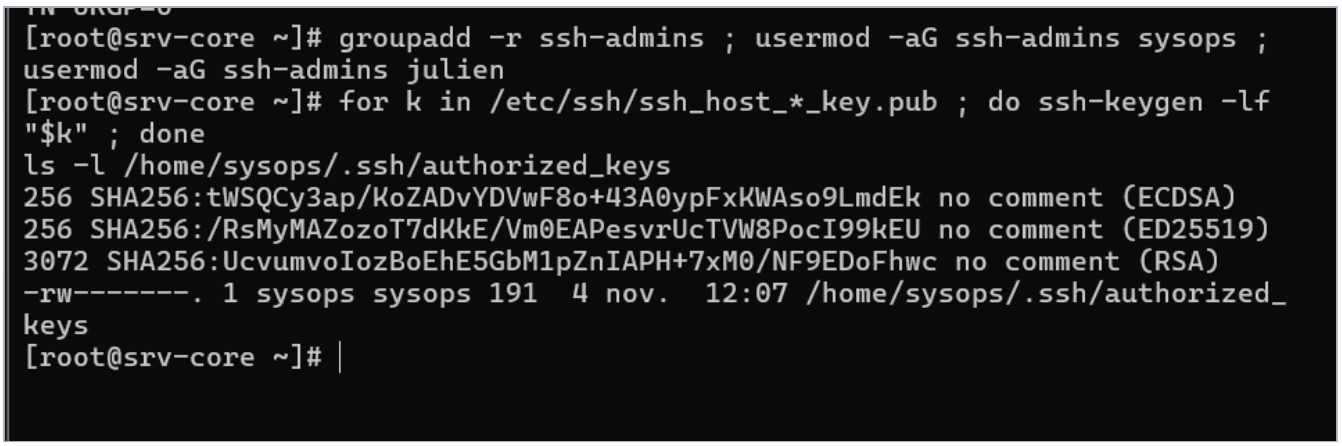
Groupe `ssh-admins` (sysops, julien). Clé ed25519 (`-a 100` : 100 tours de dérivation de la phrase de passe) générée sur srv-edge pour sysops et copiée avec `ssh-copy-id`. Une seconde clé, celle de l'hôte Windows, est ajoutée afin de conserver un accès d'administration après la suppression de l'authentification par mot de passe.



Connexion de sysops par clé depuis srv-edge, sans mot de passe



Clé de l'hôte Windows déposée et testée

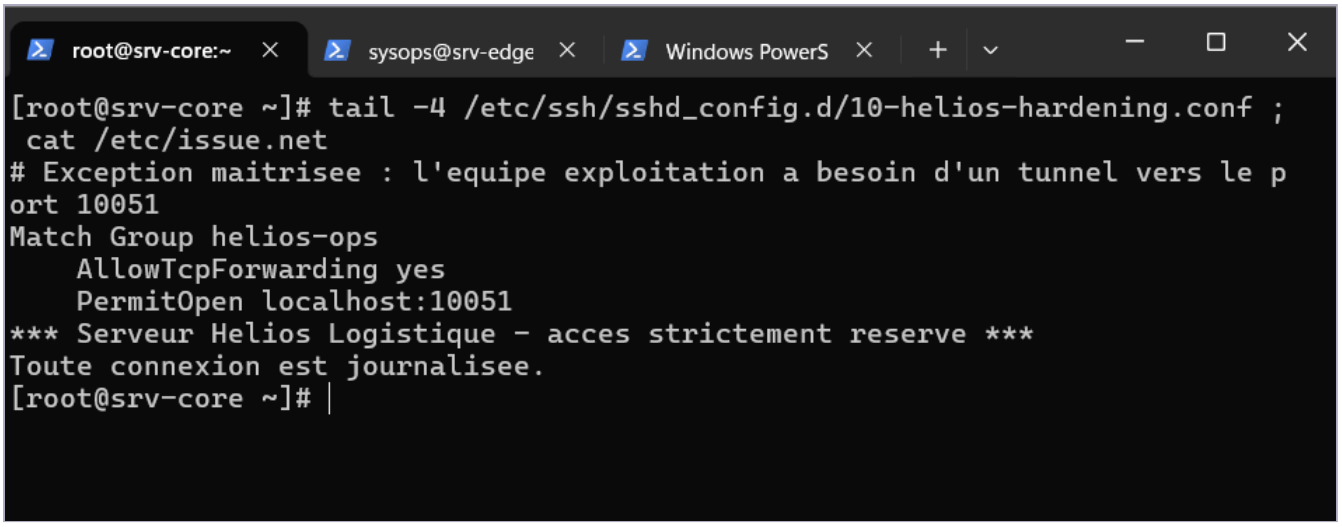


Empreintes des clés d'hôte ; authorized_keys en 0600 sysops:sysops

L'empreinte ED25519 relevée (`/RsMy…`) est celle que srv-edge présentait à sa première connexion : c'est ainsi qu'on vérifie l'identité du serveur.

2.2 Fichier de surcharge 10-helios-hardening.conf

Directives	Rôle
Port 2242, AddressFamily inet, ListenAddress ×2	Écoute uniquement sur les réseaux d'administration et métier, en IPv4, sur un port non standard
PermitRootLogin no, PasswordAuthentication no, KbdInteractiveAuthentication no, AuthenticationMethods publickey	Plus de root, plus de mot de passe : clé obligatoire
MaxAuthTries 3, MaxSessions 4, MaxStartups 10:30:60, LoginGraceTime 30	Limite les essais, les sessions et les connexions non authentifiées (anti force brute et anti saturation)
AllowGroups ssh-admins	Seuls les membres du groupe peuvent se connecter
X11/Agent/TcpForwarding no, PermitTunnel no, GatewayPorts no	Aucun tunnel ni rebond via le serveur
ClientAlive 300×2, TCPKeepAlive no	Sessions inactives fermées après 10 min
LogLevel VERBOSE, Banner	Empreinte de la clé utilisée journalisée ; avertissement légal
Match Group helios-ops	Exception maîtrisée : tunnel vers localhost:10051 seulement



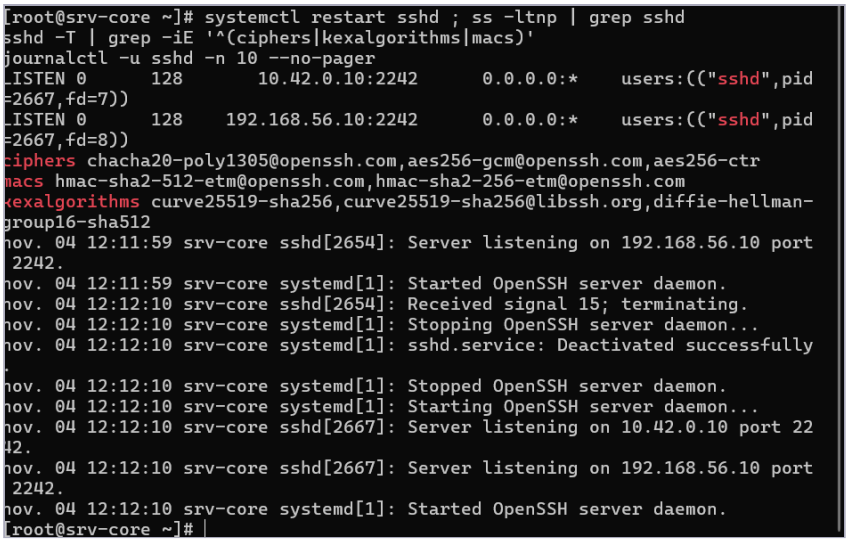
Fin du drop-in (bloc Match) et bannière /etc/issue.net – sshd -t : syntaxe OK

2.3 Algorithmes : l'interaction crypto-policies / sshd_config

```
[root@srv-core ~]# update-crypto-policies --show ; head -6 /etc/ssh/sshd_con
fig.d/50-redhat.conf
update-crypto-policies --set DEFAULT:NO-SHA1
cat > /etc/ssh/sshd_config.d/05-helios-crypto.conf <<'EOF'
HostKeyAlgorithms ssh-ed25519,rsa-sha2-512
KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org,diffie-hellman-
group16-sha512
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,aes256-ctr
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com
EOF
sshd -t && echo "syntaxe OK"
DEFAULT
# This system is following system-wide crypto policy. The changes to
# crypto properties (Ciphers, MACs, ...) will not have any effect in
# this or following included files. To override some configuration option,
# write it before this block or include it before this file.
# Please, see manual pages for update-crypto-policies(8) and sshd_config(5).
Include /etc/crypto-policies/back-ends/opensshserver.config
Setting system policy to DEFAULT:NO-SHA1
Note: System-wide crypto policies are applied on application start-up.
It is recommended to restart the system for the change of policies
to fully take place.
syntaxe OK
[root@srv-core ~]#
```

Politique DEFAULT → DEFAULT:NO-SHA1 ; en-tête de 50-redhat.conf

> Sur RHEL/Rocky 9, `/etc/ssh/sshd_config` inclut d'abord `sshd_config.d/*.conf` par ordre alphabétique. `50-redhat.conf` inclut à son tour `/etc/crypto-policies/back-ends/opensshserver.config`, généré par la politique cryptographique système. Or **sshd retient la première valeur lue** pour chaque directive. Deux approches :
> (a) **durcir la politique système** (`update-crypto-policies --set DEFAULT:NO-SHA1`), ce qui s'applique à sshd mais aussi à toutes les bibliothèques (OpenSSL, GnuTLS…) ; c'est l'approche recommandée ;
> (b) un drop-in **lu avant** 50-redhat.conf : d'où le nom `05-helios-crypto.conf`. Ajoutées à la fin de 10-helios-hardening.conf, ces directives seraient lues après la politique (sans effet), voire dans le bloc `Match`, où sshd les refuse.



sshd -T : ciphers, kex et MACs du fichier 05 appliqués ; écoute sur 192.168.56.10:2242 et 10.42.0.10:2242

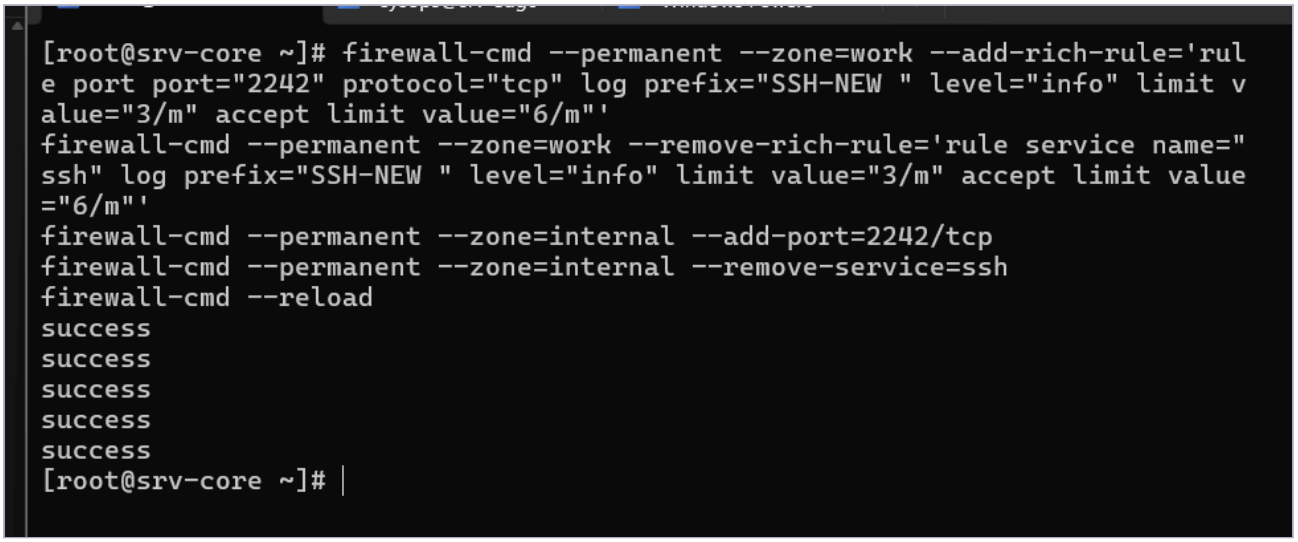
2.4 Changement de port : trois conséquences sur RHEL 9

1. **sshd** doit écouter sur le nouveau port (`Port 2242`).
2. **SELinux** : sshd n'a le droit de se lier qu'aux ports de type `ssh_port_t`. Sans `semanage port -a -t ssh_port_t -p tcp 2242`, il refuse de démarrer (refus AVC).
3. **Le pare-feu** doit ouvrir 2242, et le service « ssh » (port 22) est retiré, sinon le port 22 resterait ouvert alors que plus rien n'y écoute.

Pour ne pas se couper, l'ordre a été : SELinux, puis pare-feu, puis redémarrage de sshd, avec une session root et la console VirtualBox gardées ouvertes.



semanage port -l | grep ssh_port_t → tcp 2242, 22



Règle riche déplacée de ssh/22 vers 2242, zone internal mise à jour

```
PS C:\Users\bilel> ssh -p 2242 sysops@192.168.56.10 hostname
*** Serveur Helios Logistique - acces strictement reserve ***
Toute connexion est journalisee.
srv-core
PS C:\Users\bilel>
```

Première connexion sur 2242 depuis l'hôte : bannière Hélios, puis srv-core

2.5 Les sept tests depuis srv-edge

```
[sysops@srv-edge ~]$ nc -zv -w2 192.168.56.10 22 ; echo "1. ancien port : ec
hec attendu ($?)"
Ncat: Version 7.92 ( https://nmap.org/ncat )
Ncat: No route to host.
1. ancien port : echec attendu (1)
[sysops@srv-edge ~]$ ssh -p 2242 sysops@192.168.56.10 'hostname; id -nG'
*** Serveur Helios Logistique - acces strictement reserve ***
Toute connexion est journalisee.
srv-core
sysops wheel ssh-admins
[sysops@srv-edge ~]$ ssh -p 2242 root@192.168.56.10 'id' ; echo "3. root : e
chec attendu ($?)"
*** Serveur Helios Logistique - acces strictement reserve ***
Toute connexion est journalisee.
root@192.168.56.10: Permission denied (publickey).
3. root : echec attendu (255)
[sysops@srv-edge ~]$ ssh -p 2242 -o PubkeyAuthentication=no -o PreferredAuth
entications=password sysops@192.168.56.10 ; echo "4. mot de passe : echec at
tendu ($?)"
*** Serveur Helios Logistique - acces strictement reserve ***
Toute connexion est journalisee.
sysops@192.168.56.10: Permission denied (publickey).
4. mot de passe : echec attendu (255)
[sysops@srv-edge ~]$ ssh -p 2242 nadia@192.168.56.10 ; echo "5. hors ssh-adm
ins : echec attendu ($?)"
*** Serveur Helios Logistique - acces strictement reserve ***
Toute connexion est journalisee.
nadia@192.168.56.10: Permission denied (publickey).
5. hors ssh-admins : echec attendu (255)
[sysops@srv-edge ~]$ ssh -p 2242 -N -L 9999:localhost:10051 sysops@192.168.5
6.10 & sleep 2
nc -zv -w2 127.0.0.1 9999 ; sleep 1 ; kill %1 2>/dev/null
[1] 2291
*** Serveur Helios Logistique - acces strictement reserve ***
Toute connexion est journalisee.
Ncat: Version 7.92 ( https://nmap.org/ncat )
Ncat: Connected to 127.0.0.1:9999.
Ncat: 0 bytes sent, 0 bytes received in 0.02 seconds.
channel 2: open failed: administratively prohibited: open failed
[sysops@srv-edge ~]$
```

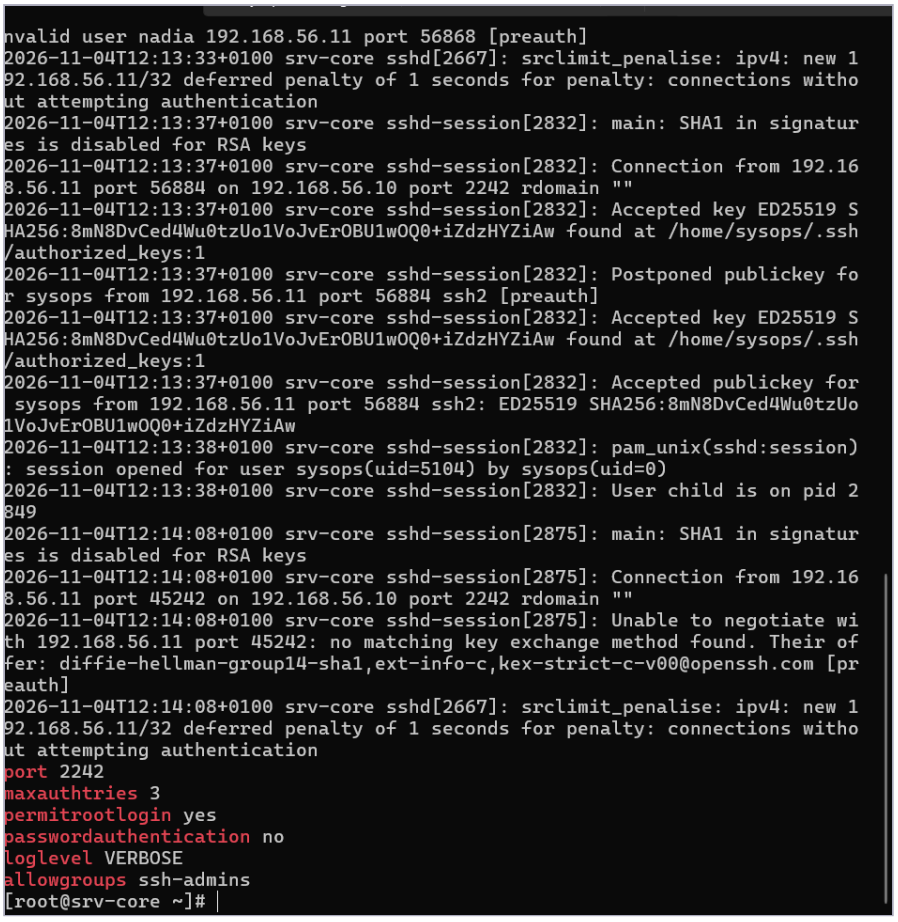
Tests 1 à 6

```
[1]+  Fini                    ssh -p 2242 -N -L 9999:localhost:10051 sysops@
192.168.56.10
[sysops@srv-edge ~]$ sleep 15
ssh -p 2242 -o KexAlgorithms=diffie-hellman-group14-sha1 sysops@192.168.56.1
0 ; echo "7. KEX SHA-1 : echec attendu ($?)"
Unable to negotiate with 192.168.56.10 port 2242: no matching key exchange m
ethod found. Their offer: curve25519-sha256,curve25519-sha256@libssh.org,dif
fie-hellman-group16-sha512,ext-info-s,kex-strict-s-v00@openssh.com
7. KEX SHA-1 : echec attendu (255)
[sysops@srv-edge ~]$
```

Test 7 : KEX SHA-1 refusé

#	Test	Résultat observé	Trace côté serveur
1	Port 22	No route to host, rc=1	REJECT noyau (plus rien n'écoute, port fermé)

2	sysops par clé	srv-core, groupes sysops wheel ssh-admins	Accepted publickey … ED25519 SHA256:8mN8…
3	root	Permission denied (publickey)	Refus avant authentification
4	Mot de passe forcé	Permission denied (publickey) : la méthode n'est pas proposée	–
5	nadia	Permission denied	Invalid user nadia … [preauth]
6	Tunnel vers 10051	Connexion établie, puis « administratively prohibited »	Refus du transfert à l'usage (sysops hors helios-ops)
7	KEX SHA-1	no matching key exchange method	Unable to negotiate … Their offer: diffie-hellman-group14-sha1



Journal sshd des tests, puis sshd -T : permitrootlogin yes inattendu

2.6 Faille découverte : PermitRootLogin écrasé

> `sshd -T` affichait `permitrootlogin yes` malgré le drop-in. Cause : l'installeur Rocky (case « Autoriser la connexion SSH root avec mot de passe ») avait créé `/etc/ssh/sshd_config.d/01-permitrootlogin.conf`. Lu **avant** 10-helios-hardening.conf, il l'emporte (première valeur lue). Root n'était refusé au test 3 que faute de clé. Le fichier a été supprimé : `permitrootlogin no`. Leçon : toujours vérifier la configuration **effective** (`sshd -T`), et pas seulement le fichier écrit.

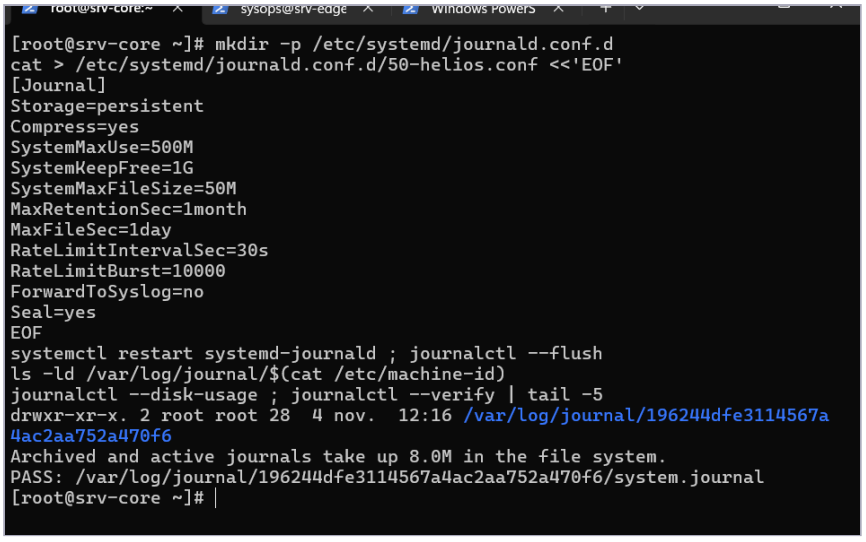
```
[root@srv-core ~]# grep -rn PermitRootLogin /etc/ssh/sshd_config.d/
/etc/ssh/sshd_config.d/01-permitrootlogin.conf:3:PermitRootLogin yes
/etc/ssh/sshd_config.d/10-helios-hardening.conf:7:PermitRootLogin no
[root@srv-core ~]# rm -f /etc/ssh/sshd_config.d/01-permitrootlogin.conf
sshd -t && systemctl reload sshd
sshd -T | grep -iE 'permitrootlogin|passwordauthentication|allowgroups'
permitrootlogin no
passwordauthentication no
allowgroups ssh-admins
[root@srv-core ~]# grep -rn PermitRootLogin /etc/ssh/sshd_config.d/
/etc/ssh/sshd_config.d/10-helios-hardening.conf:7:PermitRootLogin no
[root@srv-core ~]#
```

grep du fichier coupable, suppression, sshd -T conforme

Mission 3 – Surveillance des journaux et détection

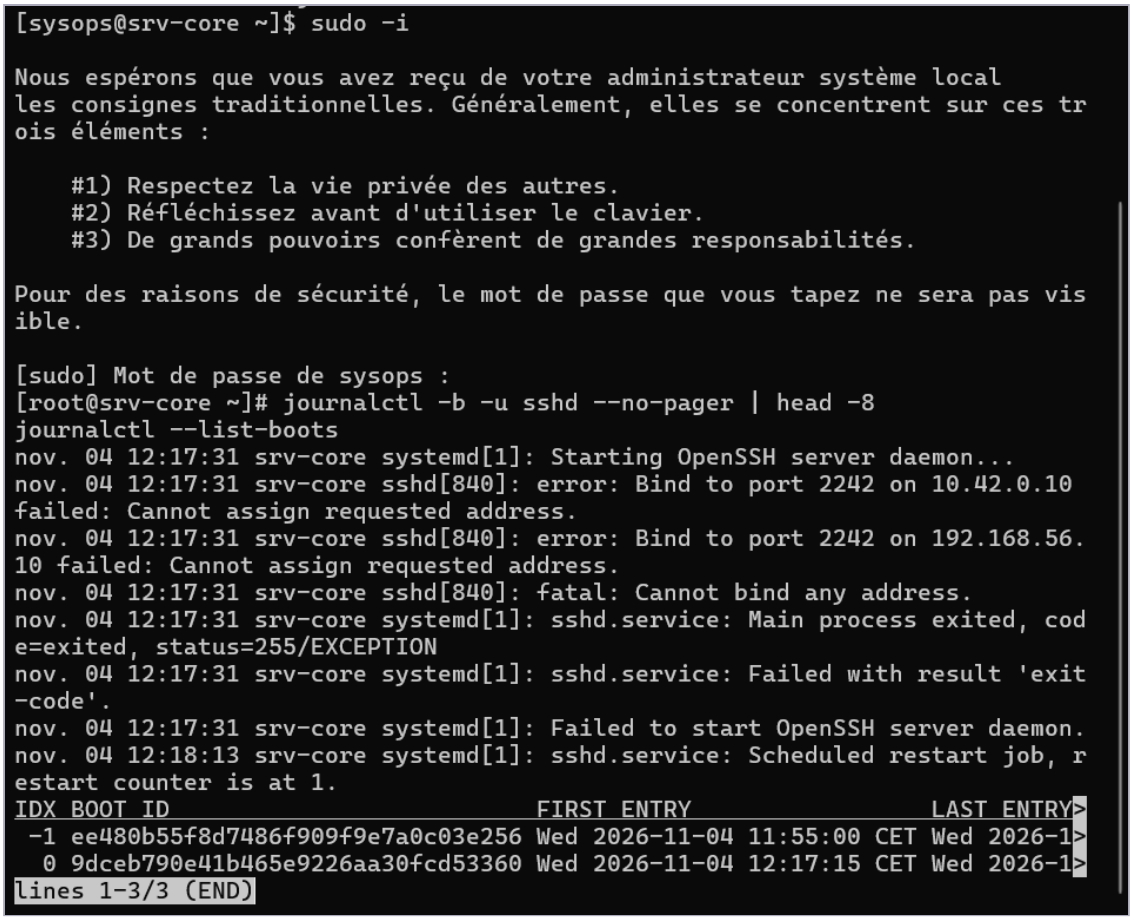
3.1 journald persistant

`Storage=persistent` (écriture dans /var/log/journal), compression, 500 Mo maximum avec 1 Go de disque toujours libre, rotation quotidienne, rétention d'un mois, pas de doublon vers syslog. `Seal=yes` n'est effectif qu'après génération d'une clé (`journalctl --setup-keys`), non réalisée ici.



Répertoire persistant créé, 8 Mo utilisés, journalctl --verify : PASS

> **Incident au redémarrage :** sshd a échoué au boot (`Bind to port 2242 on 10.42.0.10 failed: Cannot assign requested address`), car `NetworkManager-wait-online` est masqué depuis le TP1 : sshd démarre avant que les adresses imposées par `ListenAddress` existent. systemd l'a relancé 40 s plus tard. Correction durable : `net.ipv4.ip_nonlocal_bind = 1` (configs/90-helios-sshd.conf).



Échec de sshd au boot, puis journalctl --list-boots : 2 démarrages

3.2 Requêtes d'investigation

Requête	Ce qu'elle révèle
`journalctl _SYSTEMD_UNIT=sshd.service -g 'Invalid user|Failed|Accepted'`	Chaque connexion acceptée avec l'empreinte de la clé : clé de srv-edge (8mN8…, depuis .11) et clé de l'hôte (2nty…, depuis .1, ligne 2 de authorized_keys). On sait qui s'est connecté et avec quelle clé.
`journalctl --facility=authpriv --since today`	Le fil complet d'une session : SSH de sysops, ouverture PAM, puis `sudo -i` vers root à 12:19:41 (élévation de privilèges).
`journalctl -t sudo -o json-pretty`	Le même événement avec tous ses champs, dont `_AUDIT_LOGINUID=5104` : l'identité réelle reste connue derrière root. Format exploitable par un SIEM.
`journalctl -b -1 -p err`	Les erreurs du démarrage précédent (pilote e1000, carte graphique VMSVGA) : consultable uniquement grâce à la persistance.
`lastb ; last -F ; lslogins`	Les 6 échecs de nadia (test faillock du TP2), des sessions root « crash » (arrêts brutaux de la VM), les mots de passe de root et bilel jamais changés, l'expiration de audit-ext au 24/11.

```
daemon.
nov. 04 12:13:11 srv-core sshd-session[2764]: Accepted publickey for sysops
from 192.168.56.11 port 54086 ssh2: ED25519 SHA256:8mN8DvCed4Wu0tzUo1VoJvErO
BU1wOQ0+iZdzHYZiAw
nov. 04 12:13:37 srv-core sshd-session[2832]: Accepted key ED25519 SHA256:8m
N8DvCed4Wu0tzUo1VoJvErOBU1wOQ0+iZdzHYZiAw found at /home/sysops/.ssh/authori
zed_keys:1
nov. 04 12:13:37 srv-core sshd-session[2832]: Accepted key ED25519 SHA256:8m
N8DvCed4Wu0tzUo1VoJvErOBU1wOQ0+iZdzHYZiAw found at /home/sysops/.ssh/authori
zed_keys:1
nov. 04 12:13:37 srv-core sshd-session[2832]: Accepted publickey for sysops
from 192.168.56.11 port 56884 ssh2: ED25519 SHA256:8mN8DvCed4Wu0tzUo1VoJvErO
BU1wOQ0+iZdzHYZiAw
-- Boot 9dceb790e41b465e9226aa30fcd53360 --
nov. 04 12:18:51 srv-core sshd-session[977]: Accepted key ED25519 SHA256:2nt
ygwPK/lotO4cFSnnUJFjd5NOBzTlLnFp+bJwFKOU found at /home/sysops/.ssh/authoriz
ed_keys:2
nov. 04 12:18:51 srv-core sshd-session[977]: Accepted key ED25519 SHA256:2nt
ygwPK/lotO4cFSnnUJFjd5NOBzTlLnFp+bJwFKOU found at /home/sysops/.ssh/authoriz
ed_keys:2
nov. 04 12:18:52 srv-core sshd-session[977]: Accepted publickey for sysops f
rom 192.168.56.1 port 61456 ssh2: ED25519 SHA256:2ntygwPK/lotO4cFSnnUJFjd5NO
BzTlLnFp+bJwFKOU
nov. 04 12:18:51 srv-core sshd-session[977]: Accepted key ED25519 SHA256:2nt
ygwPK/lotO4cFSnnUJFjd5NOBzTlLnFp+bJwFKOU found at /home/sysops/.ssh/authoriz
ed_keys:2
nov. 04 12:18:52 srv-core sshd-session[977]: Accepted publickey for sysops f
rom 192.168.56.1 port 61456 ssh2: ED25519 SHA256:2ntygwPK/lotO4cFSnnUJFjd5NO
BzTlLnFp+bJwFKOU
nov. 04 12:18:52 srv-core systemd[981]: pam_unix(systemd-user:session): sess
ion opened for user sysops(uid=5104) by sysops(uid=0)
nov. 04 12:18:52 srv-core sshd-session[977]: pam_unix(sshd:session): session
 opened for user sysops(uid=5104) by sysops(uid=0)
nov. 04 12:18:52 srv-core sshd-session[977]: User child is on pid 990
nov. 04 12:18:52 srv-core sshd-session[990]: Starting session: shell on pts/
0 for sysops from 192.168.56.1 port 61456 id 0
nov. 04 12:19:41 srv-core sudo[1053]:   sysops : TTY=pts/0 ; PWD=/root ; USE
R=root ; COMMAND=/bin/bash
nov. 04 12:19:41 srv-core sudo[1053]: pam_unix(sudo-i:session): session open
ed for user root(uid=0) by sysops(uid=5104)
[root@srv-core ~]#
```

Connexions acceptées par clé et sudo -i de sysops

```
        "__REALTIME_TIMESTAMP" : "1793791181827876",
        "_AUDIT_SESSION" : "1",
        "_RUNTIME_SCOPE" : "system",
        "_COMM" : "sudo",
        "SYSLOG_FACILITY" : "10",
        "_CAP_EFFECTIVE" : "1ffffffffff",
        "_SYSTEMD_CGROUP" : "/user.slice/user-5104.slice/session-1.scope",
        "PRIORITY" : "5",
        "_SYSTEMD_USER_SLICE" : "-.slice",
        "_AUDIT_LOGINUID" : "5104",
        "_SYSTEMD_OWNER_UID" : "5104",
        "_BOOT_ID" : "9dceb790e41b465e9226aa30fcd53360",
        "__MONOTONIC_TIMESTAMP" : "149912701",
        "MESSAGE" : "  sysops : TTY=pts/0 ; PWD=/root ; USER=root ; COMMAND=
/bin/bash",
        "_TRANSPORT" : "syslog",
        "_GID" : "5104",
        "_SYSTEMD_UNIT" : "session-1.scope",
        "_SYSTEMD_INVOCATION_ID" : "7362638e7d3040d9a3780b580cce46ad",
        "_UID" : "5104",
        "_SYSTEMD_SLICE" : "user-5104.slice",
        "_CMDLINE" : "sudo -i",
        "_SOURCE_REALTIME_TIMESTAMP" : "179379118826444",
        "_SYSTEMD_SESSION" : "1",
nov. 04 11:55:02 srv-core kernel: Warning: Unmaintained driver is detected:
e1000
nov. 04 11:55:02 srv-core kernel: Warning: Unmaintained driver is detected:
e1000
nov. 04 11:55:02 srv-core kernel: Warning: Unmaintained driver is detected:
e1000_init_module
nov. 04 11:55:19 srv-core kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx
seems to be running on an unsupported hypervisor.
nov. 04 11:55:19 srv-core kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This co
nfiguration is likely broken.
nov. 04 11:55:19 srv-core kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please
switch to a supported graphics device to avoid problems.
nov. 04 12:16:51 srv-core sshd-session[1086]: error: mm_reap: preauth child
terminated by signal 15
nov. 04 12:16:52 srv-core dbus-broker-launch[723]: Activation request for 'o
rg.freedesktop.nm_dispatcher' failed.
[root@srv-core ~]#
```

Événement sudo en JSON ; erreurs du boot précédent

```
nadia    pts/1                        Tue Nov  3 11:25 - 11:25  (00:00)
nadia                                 Tue Nov  3 11:07 - 11:07  (00:00)
nadia                                 Tue Nov  3 11:07 - 11:07  (00:00)
nadia                                 Tue Nov  3 11:07 - 11:07  (00:00)
nadia                                 Tue Nov  3 11:07 - 11:07  (00:00)
nadia                                 Tue Nov  3 11:07 - 11:07  (00:00)
nadia                                 Tue Nov  3 11:07 - 11:07  (00:00)
root     tty1                         Mon Nov  2 12:02 - 12:02  (00:00)

btmp commence Mon Nov  2 12:02:52 2026
sysops   pts/0        192.168.56.1     Wed Nov  4 12:18:52 2026   still logg
ed in
reboot   system boot  5.14.0-687.61.1. Wed Nov  4 12:17:23 2026   still runn
ing
root     pts/0        192.168.56.1     Wed Nov  4 11:57:39 2026 - Wed Nov  4
 12:16:52 2026  (00:19)
root     tty1                          Wed Nov  4 11:57:16 2026 - down
              (00:19)
reboot   system boot  5.14.0-687.61.1. Wed Nov  4 11:55:13 2026 - Wed Nov  4
 12:16:57 2026  (00:21)
root     pts/1        192.168.56.1     Tue Nov  3 11:00:37 2026 - crash
             (1+00:54)
root     pts/0        192.168.56.1     Tue Nov  3 10:59:07 2026 - crash
             (1+00:56)
reboot   system boot  5.14.0-687.61.1. Tue Nov  3 10:58:13 2026 - Wed Nov  4
 12:16:57 2026 (1+01:18)
root     pts/0        192.168.56.1     Mon Nov  2 13:59:19 2026 - crash
             (20:58)
reboot   system boot  5.14.0-687.61.1. Mon Nov  2 13:58:18 2026 - Wed Nov  4
 12:16:57 2026 (1+22:18)

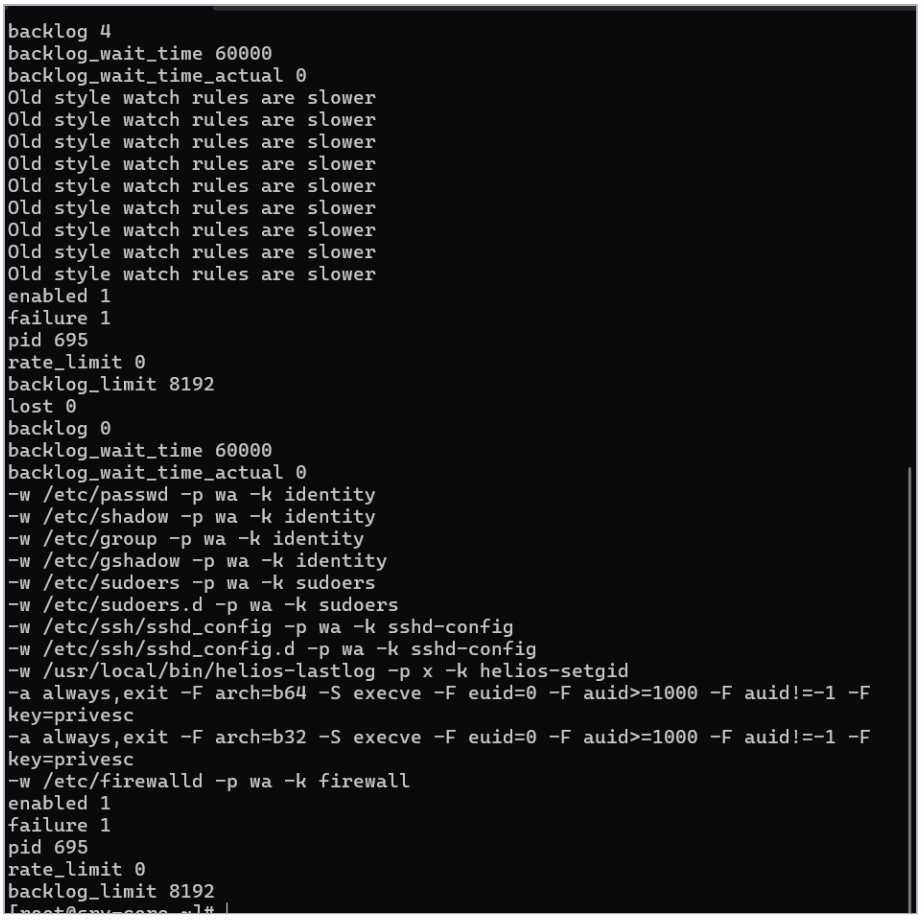
wtmp commence Mon Nov  2 12:01:55 2026
USER       PWD-CHANGE    PWD-EXPIR   LAST-LOGIN FAILED-LOGIN
root      1969-déc.31                    11:57 11:57
bilel     1969-déc.31
julien    nov.02/01:00             nov.03/11:21
nadia     nov.03/01:00             nov.03/11:39 nov.03/11:25
tarek     nov.03/01:00             nov.03/11:15
audit-ext nov.03/01:00 nov.24/01:00 nov.03/11:48
sysops          01:00                  12:18
[root@srv-core ~]#
```

lastb, last -F, lslogins

3.3 auditd

journald enregistre ce que les programmes disent ; auditd enregistre ce que le noyau voit. Les 14 règles surveillent les fichiers d'identité, sudoers, la configuration sshd, l'exécution du binaire setgid

du TP2, firewalld, et toute commande exécutée en root par un compte humain (`euid=0`, `auid>=1000`).



auditctl -l : 14 règles chargées ; auditctl -s : enabled 1

```
linkat success=yes exit=0 a0=AT_FDCWD a1=0x555d125ef4d0 a2=0x0 a3=0x100 item
s=2 ppid=1070 pid=1329 auid=sysops uid=root gid=root euid=root suid=root fsu
id=root egid=root sgid=root fsgid=root tty=pts1 ses=1 comm=rm exe=/usr/bin/r
m subj=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023 key=sudoers
type=PATH msg=audit(04/11/2026 12:22:48.886:176) : item=1 name=/lib64/ld-lin
ux-x86-64.so.2 inode=50331788 dev=fd:00 mode=file,755 ouid=root ogid=root rd
ev=00:00 obj=system_u:object_r:ld_so_t:s0 nametype=NORMAL cap_fp=none cap_fi
=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(04/11/2026 12:22:48.886:176) : item=0 name=/bin/tail ino
de=34347556 dev=fd:00 mode=file,755 ouid=root ogid=root rdev=00:00 obj=syste
m_u:object_r:bin_t:s0 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_f
ver=0 cap_frootid=0
type=CWD msg=audit(04/11/2026 12:22:48.886:176) : cwd=/root
type=EXECVE msg=audit(04/11/2026 12:22:48.886:176) : argc=2 a0=tail a1=-12
type=SYSCALL msg=audit(04/11/2026 12:22:48.886:176) : arch=x86_64 syscall=ex
ecve success=yes exit=0 a0=0x5584d625a0c0 a1=0x5584d625b2b0 a2=0x5584d62256e
0 a3=0x8 items=2 ppid=1070 pid=1408 auid=sysops uid=root gid=root euid=root
suid=root fsuid=root egid=root sgid=root fsgid=root tty=pts1 ses=1 comm=tail
 exe=/usr/bin/tail subj=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c102
3 key=privesc
----
type=PROCTITLE msg=audit(04/11/2026 12:22:48.886:177) : proctitle=ausearch -
k privesc -i --start today
type=PATH msg=audit(04/11/2026 12:22:48.886:177) : item=1 name=/lib64/ld-lin
ux-x86-64.so.2 inode=50331788 dev=fd:00 mode=file,755 ouid=root ogid=root rd
ev=00:00 obj=system_u:object_r:ld_so_t:s0 nametype=NORMAL cap_fp=none cap_fi
=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(04/11/2026 12:22:48.886:177) : item=0 name=/sbin/ausearc
h inode=50966020 dev=fd:00 mode=file,755 ouid=root ogid=root rdev=00:00 obj=
system_u:object_r:bin_t:s0 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0
cap_fver=0 cap_frootid=0
type=CWD msg=audit(04/11/2026 12:22:48.886:177) : cwd=/root
type=EXECVE msg=audit(04/11/2026 12:22:48.886:177) : argc=6 a0=ausearch a1=-
k a2=privesc a3=-i a4=--start a5=today
type=SYSCALL msg=audit(04/11/2026 12:22:48.886:177) : arch=x86_64 syscall=ex
ecve success=yes exit=0 a0=0x5584d625a0c0 a1=0x5584d6256330 a2=0x5584d62256e
0 a3=0x8 items=2 ppid=1070 pid=1407 auid=sysops uid=root gid=root euid=root
suid=root fsuid=root egid=root sgid=root fsgid=root tty=pts1 ses=1 comm=ause
arch exe=/usr/sbin/ausearch subj=unconfined_u:unconfined_r:unconfined_t:s0-s
0:c0.c1023 key=privesc
[root@srv-core ~]#
```

ausearch -k privesc -i : commandes root avec auid=sysops ; événement sudoers (rm dans /etc/sudoers.d)

Le champ **auid** (audit UID), fixé à la connexion, n'est pas modifié par `sudo` ou `su` : derrière root, on retrouve toujours le compte humain d'origine (sysops).

```
Failed Summary Report
=====================
Range of time in logs: 02/11/2026 12:01:59.207 - 04/11/2026 12:22:14.515
Selected time for report: 02/11/2026 12:01:59 - 04/11/2026 12:22:14.515
Number of changes in configuration: 0
Number of changes to accounts, groups, or roles: 2
Number of logins: 0
Number of failed logins: 8
Number of authentications: 0
Number of failed authentications: 26
Number of users: 2
Number of terminals: 7
Number of host names: 4
Number of executables: 6
Number of commands: 1
Number of files: 0
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 0
Number of anomaly events: 0
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 0
Number of process IDs: 56
Number of events: 75


Key Summary Report
==========================
total  key
==========================
18  privesc
4  identity
4  sudoers
2  sshd-config
2  helios-setgid
1  firewall
[root@srv-core ~]#
```

aureport --failed (8 connexions, 26 authentifications échouées) et aureport -k

3.4 Détection et blocage automatiques

`helios-watch-auth.sh` (configs/) : sur une fenêtre de 10 minutes, il compte par adresse source les lignes sshd « Invalid user » et « Failed password/publickey », puis ajoute à l'ipset `helios-blacklist` toute adresse dépassant 5 échecs.

- mode strict (`set -euo pipefail`, IFS restreint) ;

- verrou `flock -n` : code retour **2** si une instance tourne déjà, sinon **0** ;
- journalisation via `logger -t helios-watch-auth` ;
- liste blanche en dur : 192.168.56.1 (poste formateur/hôte) et 127.0.0.1 ;
- idempotence : adresse déjà présente dans `/var/lib/helios/blocked.txt` ou dans l'ipset → aucune seconde alerte.

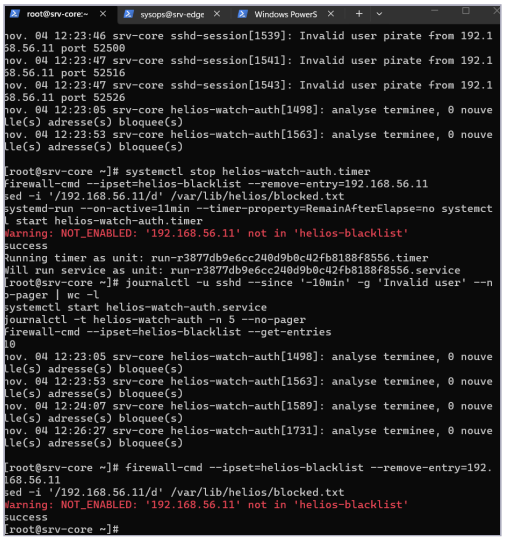
Service `oneshot` dépendant de firewalld, et timer `OnCalendar=*:0/2`, `AccuracySec=10s`, `Persistent=no` (rattraper une analyse manquée n'a pas de sens pour une détection en temps réel).



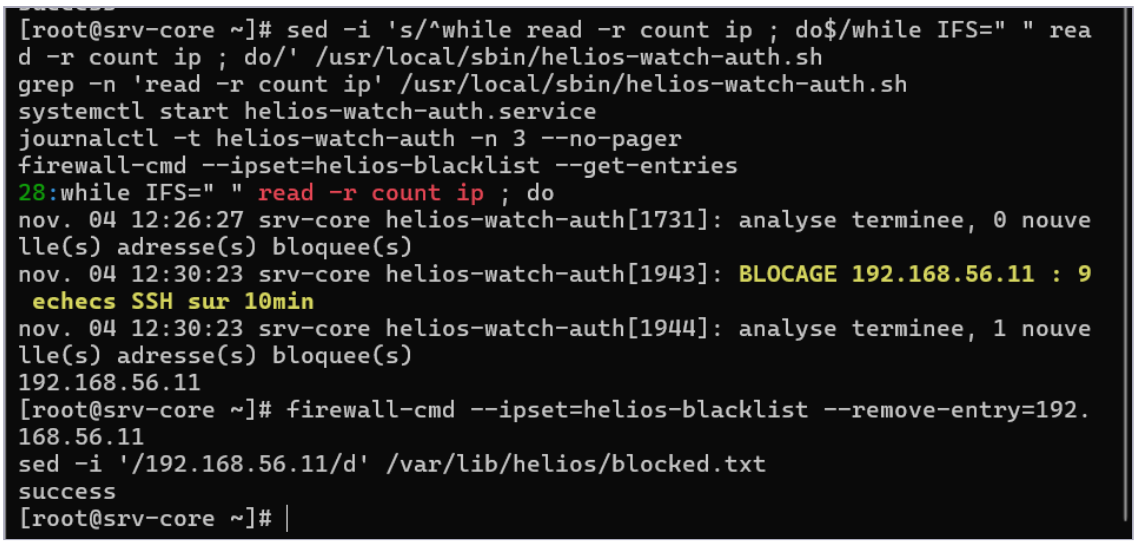
Première exécution rc=0 (0 adresse) ; timer actif, prochaine exécution dans 54 s

Premier essai : seulement 5 échecs enregistrés, car la limite de débit du pare-feu (6/m) a jeté les autres tentatives avant sshd. Le seuil (> 5) n'était pas atteint : les deux protections se complètent (le pare-feu freine les rafales, le script bloque l'attaquant qui insiste). Une seconde série espacée de 20 s a porté le total à 10.

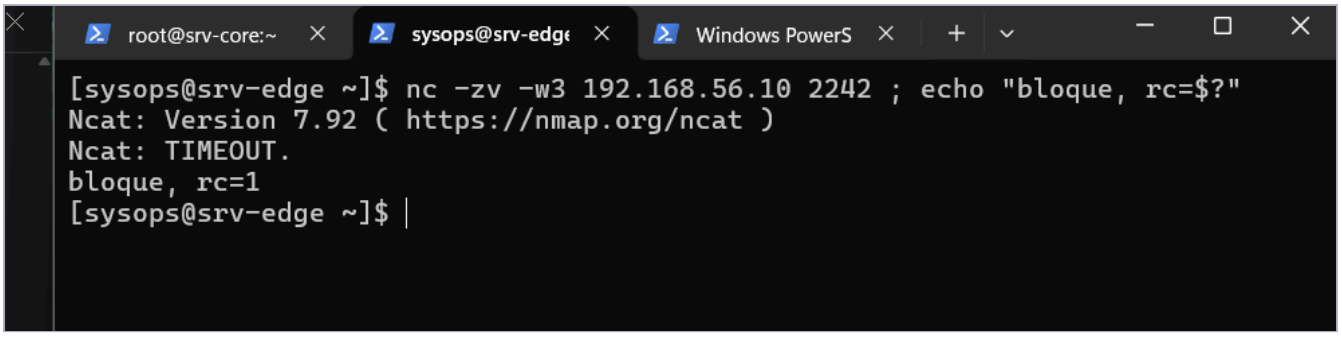
> **Bug corrigé :** malgré 10 échecs, le script n'a d'abord rien bloqué. Avec `IFS=$'\n\t'` (mode strict), `read count ip` ne coupait pas la sortie de `uniq -c` sur les espaces : l'IP restait vide. Correction : `while IFS=" " read -r count ip`.



10 « Invalid user » mais 0 adresse bloquée, avant correction



BLOCAGE 192.168.56.11 : 9 échecs SSH sur 10 min – ipset peuplé – déblocage



Depuis srv-edge : TIMEOUT sur 2242, la source est bien bloquée

Déblocage : timer arrêté, entrée retirée de l'ipset et du fichier d'état, puis timer relancé 11 minutes plus tard avec `systemd-run`, une fois les échecs sortis de la fenêtre de 10 minutes.

Conclusion

Fichier (configs/)	Rôle
zones.txt	firewall-cmd --list-all-zones
10-helios-hardening.conf, 05-helios-crypto.conf, issue.net	Durcissement sshd, algorithmes, bannière
90-helios-sshd.conf	sysctl ip_nonlocal_bind (correctif de démarrage)
50-helios-journald.conf	journald persistant
90-helios.rules	Règles auditd
helios-watch-auth.sh / .service / .timer	Détection et blocage automatiques

Les trois constats de l'audit sont traités : le filtrage est segmenté par zone avec une politique « tout fermé par défaut » ; SSH n'accepte plus que des clés, pour le seul groupe ssh-admins, sur un port dédié et avec des algorithmes modernes ; les journaux sont persistants, auditd trace les actions sensibles, et les attaques répétées sont bloquées automatiquement.

Enseignements : vérifier la configuration effective (`sshd -T`, `nft list`) plutôt que les fichiers écrits ; un ordre de lecture des fichiers peut annuler une directive (crypto-policies, PermitRootLogin) ; toujours tester un accès de remplacement avant de couper l'ancien.

Non réalisé : la mission bonus (immuabilité auditd, revue cryptographique) et le scan nmap « après » durcissement.